

Hito 6

Calidad Interna & SecDevOps

Entregable 6 · Análisis Estático del Código y Evaluación de Seguridad

Dictamen ejecutivo

El sistema presenta una arquitectura DDD con fronteras de dominio limpias, autorización por roles y territorio aplicada también a los canales en tiempo real. No obstante, no se recomienda iniciar E7 como gate formal hasta actualizar el árbol npm desplegable, proteger la sesión frente a XSS, incorporar CSP/HSTS y restablecer la base de pruebas funcionales. La deuda de mantenibilidad es moderada-alta por funciones extensas y acoplamiento en la capa de presentación.

Autores

Damián Jesús Torres Cadena
Melanie Adriana Tomalá Merejildo
Jean Pierre Cedeño Andrade

Docente	Ing. Anthony Pachay
Marco	OWASP Top 10:2025 · ISO/IEC 25010:2023
Corte	13 de julio de 2026 · commit 2ccb77c7

Línea base y toolkit de análisis

Alcance: backend Laravel/PHP, frontend JavaScript estático, configuración y locks de dependencias

Herramienta	Propósito	Aplicación
Métrica propia + PHP -I	LOC, strict types, longitud, complejidad heurística y sintaxis	346 archivos / 263 PHP
ESLint 8.57.1	Errores de símbolos, variables no usadas y flujo inalcanzable	48 módulos JS de aplicación
jscpd 4.0.5	Clones y densidad de duplicación	backend/app + frontend/app/js
Laravel Pint	Deuda de estilo PSR-12/Laravel	Código PHP del proyecto
Composer / npm audit	Advisories, CVE y paquetes abandonados	composer.lock + package-lock.json
Revisión dirigida	OWASP 2025, RBAC, realtime, correo, nginx, Docker y CI	Código/configuración versionada

34,278

líneas netas de código

2.62%

duplicación global

21

errores ESLint

0

errores sintaxis PHP

```
E01-E02 · métricas y duplicación

$ python scripts/hito6_static_metrics.py
files=346 total_lines=42,477 code=34,278 comments=2,383 blank=5,816
strict_types=7/263 (2.66%) functions>60=42 complexity~>10=59
Domain->Illuminate=0 Facades_in_Application=0
$ npx jscpd@4.0.5 backend/app frontend/app/js --reporters console,json
sources=270 clones=51 duplicated_lines=617 duplication=2.62%
javascript=1.40% php=3.51%
```

Figura 1. Evidencia E01-E02. La complejidad es una estimación lexical; no sustituye SonarQube, pero permite priorizar refactorizaciones reproducibles.

Lectura de calidad interna

La duplicación de 2.62% es controlable; el principal pasivo no es copiar código sino concentrar decisiones. Se detectaron 42 funciones mayores de 60 líneas y 59 por encima de complejidad ~10 (con solapamiento). Solo 7 de 263 archivos PHP declaran strict_types. Como fortalezas, no existen dependencias Domain→Illuminate ni Facades en Application.

Diagnóstico de mantenibilidad

Los valores de complejidad son heurísticos y se usan como ranking, no como certificación

Componente	Método / función	Líneas	CC~	Diagnóstico
auth-page.js:18	initAuthPage	850	158	Clase Dios funcional: login, registro, Google y validación.
layout.js:659	renderLayout	193	51	Mezcla menú, sesión, notificaciones y eventos globales.
reports-page.js:204	buildAnalytics	124	33	Cálculo, narrativa y transformación en un bloque.
operational-structure-page.js:972	updateTeamManagementTab	99	32	UI y reglas operativas acopladas.
user-roles-page.js:43	bindActions	135	27	Múltiples flujos CRUD y estado DOM.
GoogleRegistrationUseCase.php:31	execute	129	25	Orquestación extensa con muchas ramas.

E03-E04 · lint, sintaxis y pruebas

```
$ npx eslint@8.57.1 frontend/app/js ...
files=48 files_with_findings=10 errors=21 warnings=21
$ vendor/bin/pint --test --format=json
files_with_style_findings=195 single_line_empty_body=122 phpdoc_align=25
$ php -l [263 archivos] -> syntax_failures=0
$ php artisan test --testsuite=Unit
{"result":"passed","tests":8,"assertions":24,"duration_ms":58}
$ php artisan test tests/Feature/NotificationsTest.php
failed: tests=10 errors=10; PostgreSQL password authentication failed for "user_im"
```

Figura 2. Evidencia E03–E04. ESLint requiere una configuración de globals/módulos del proyecto; por eso 21 no-undef son candidatos, no 21 fallos funcionales confirmados.

Dimensión	Resultado	Interpretación / acción
Cohesión	Mixta	DDD backend cohesivo; controladores y páginas JS concentran validación, render y eventos.
Acoplamiento	Alto en UI	Dependencia de window/localStorage y globals implícitos; modularizar adaptadores y stores.
Estilo	195 archivos	Pint evidencia deuda mecánica; aplicar por lotes con pruebas y revisión de diff.
Validación	0 FormRequest	Reglas repetidas en controladores; extraer Request classes para contratos consistentes.
Pruebas	8/8 unit; 0/10 feature	La lógica base pasa, pero la BD inválida bloquea evidencia de autorización/realtime.

Conclusión de mantenibilidad. No se identificó una ruptura de capas de dominio, pero sí módulos frontend y repositorios de más de 1,000 líneas. El refactor debe empezar por auth-page.js, layout.js y EloquentIncidentRepository.php, preservando pruebas de permisos y canales privados.

Auditoría OWASP Top 10:2025 (A01–A05)

Cada categoría declara riesgo, impacto, evidencia y remediación

Cat.	¿Riesgo? / impacto	Evidencia	Recomendación
A01	Residual · Medio. RBAC y alcance territorial son sólidos; falta convertir toda mutación de apiResource en middleware específico para evitar divergencia futura.	E06: routes/api.php:89–109; UserController:82/174/252; IncidentAccessChecker; channels.php. Menú se construye por permission_code.	Añadir middleware por acción y tests de matriz rol×recurso×territorio. Mantener doble control servidor; el menú nunca es barrera de seguridad.
A02	Sí · Alto. CSP y HSTS ausentes; SESSION_ENCRYPT=false; endpoints docs visibles y defaults sensibles dependen del entorno.	E07: nginx solo agrega X-Frame-Options, nosniff y Referrer-Policy. .env.example: SESSION_ENCRYPT=false.	CSP con nonce/hash, HSTS en TLS, cookies Secure, cifrar sesión y revisar exposición de /docs/OpenAPI en producción.
A03	Sí · Crítico/Alto. 15 avisos en dependencias de producción; cuatro críticos. Imágenes Docker y CDN usan latest/no versión.	E05/E09: npm --omit=dev: 4C/3H/7M/1L; pdftmake crítico directo; rustfs/minio latest; Vanta/MapLibre no fijados.	Actualizar dependencias directas, regenerar lock, fijar imágenes por digest, SBOM y audit como gate CI.
A04	Residual · Medio. Bcrypt=12, enlaces firmados y secretos ignorados son positivos; token bearer queda legible para JS y sesión no cifrada.	E07: auth_token en localStorage; E09: solo .env.example versionado; BCrypt_ROUND=12; URL de verificación signed.	Migrar a cookie HttpOnly+Secure+SameSite o BFF; rotar/revocar tokens y activar SESSION_ENCRYPT en producción.
A05	Sí · Alto. Eloquent y bindings reducen SQLi; existe sink DOM directo y 115 usos innerHTML que amplían el impacto de XSS.	E01/E07: dom-utils.js:29,41 asigna message a innerHTML; 27 SQL raw revisados, sin unprepared y con parámetros en consultas espaciales.	Cambiar alertas a textContent; sanitizador central y ESLint no-unsanitized; pruebas XSS. Mantener bindings para SQL raw.

E06–E08 · controles y exposición residual

```
$ rg permission: backend/routes/api.php
navigation/menu: auth:sanctum | mutations: permission middleware + controller can()
channels.php: identity + notifications.view/comments.internal + IncidentAccessChecker
$ rg localStorage frontend/app/js/core
auth-session.js:32 localStorage.setItem('auth_token', access_token)
api-client.js:31 token = localStorage.getItem('auth_token')
$ rg Security-Policy|Strict-Transport docker/production/nginx/default.conf
0 matches; X-Frame-Options, nosniff and Referrer-Policy are present
mail: tries=3 timeout=12s backoff=[3,10] after-commit; resend throttle=6/min
```

Figura 3. Evidencia E06–E08. Los controles por rol, territorio y canal privado reducen A01; la combinación localStorage + sinks DOM + ausencia de CSP mantiene exposición material.

Hallazgo encadenado prioritario

Una inyección DOM que alcance dom-utils podría leer el bearer token de localStorage; sin CSP, el navegador aporta menos contención. La remediación debe tratar los tres controles como una sola historia de seguridad.

Auditoría OWASP Top 10:2025 (A06–A10)

Cat.	¿Riesgo? / impacto	Evidencia	Recomendación
A06	Sí · Medio. No hay evidencia versionada de threat modeling; los flujos complejos de registro, roles, correo y territorio dependen de lógica distribuida.	E01/E03: initAuthPage CC~158; GoogleRegistration execute CC~25; 0 FormRequest; no artefacto de amenazas hallado.	Modelar amenazas/abuse cases y estados; extraer políticas y contratos de validación; revisar fail-safe defaults.
A07	Sí · Medio. 2FA, rate limit y expiración de 120 min son positivos; el reenvío público permite enumerar estado de cuenta.	E08: AuthController:431–446 responde distinto para inexistente, verificado y desactivado; throttle 6/min.	Respuesta y latencia uniformes; log interno del estado; CAPTCHA adaptativo y prueba de no enumeración.
A08	Sí · Alto. CDN sin SRI/versión y ausencia de CI impiden verificar integridad de artefactos antes de desplegar.	E07/E09: vanta@latest, MapLibre unpinned; no .github; locks sí están versionados.	Self-host o SRI+crossorigin; lockfiles inmutables, firma/provenance de imágenes y despliegues desde artefactos CI.
A09	Residual · Medio. Hay audit logs y login attempts; correo registra fallo definitivo. No se encontró pipeline de alertas/retención verificable.	E08: failed() registra clase y error; rutas audit protegidas. OWASP destaca que log sin alertamiento es insuficiente.	Alertas por fallos mail/queue, auth anómala y 403; redacción de PII; retención, correlación y runbooks.
A10	Sí · Medio. Reintentos cortos mejoran resiliencia; la suite de notificaciones falla por infraestructura y algunos catches silencian la causa.	E04/E08: 10/10 errores por credencial DB; correo 3 intentos, backoff 3/10 s, timeout 12 s y log final.	Health checks pretest, entorno efímero, dead-letter/failed_jobs visible y errores públicos genéricos con correlation-id.

E05 · auditoría de dependencias

```
$ composer audit --locked --format=json
advisories=0  abandoned=0  packages=134 runtime + 33 dev
$ npm audit --package-lock-only --omit=dev --json
total=15  critical=4  high=3  moderate=7  low=1
critical: pdfmake (direct), pdfkit, minimist, crypto-js
high: uplot (direct), moment (direct), jquery-validation (direct)
$ npm audit --package-lock-only --json
full lock: total=112  critical=13  high=53  moderate=40  low=6
```

Figura 4. Evidencia E05. El lock completo incluye tooling antiguo; aun excluyendo dev quedan 15 vulnerabilidades desplegables, por lo que A03 es un hallazgo confirmado.

Ecosistema	Inventario	Resultado	Decisión
Composer	134 runtime + 33 dev	0 advisories; 0 abandonados	Mantener audit en cada merge.
npm producción	209 dependencias instaladas según audit	15: 4C / 3H / 7M / 1L	Bloquea liberación hasta upgrade y retest.
npm lock total	1,350 total con transitivas	112: 13C / 53H / 40M / 6L	Renovar toolchain AdminLTE heredada.
Contenedores/CDN	Tags latest y recursos no fijados	Integridad no reproducible	Digest/SRI/self-host + SBOM.

Catálogo priorizado de hallazgos

La prioridad combina explotabilidad, impacto, cobertura y costo de corrección

ID / sev.	Debilidad y evidencia	Acción de ingeniería	Criterio de cierre
H01 · P1	Supply chain npm: 15 prod (E05)	Actualizar pdfmake/uplot/moment/jquery-validation; lock limpio.	npm audit --omit=dev sin Critical/High + regresión UI.
H02 · P1	XSS→token: localStorage, sink DOM, sin CSP (E07)	Cookie HttpOnly o BFF; textContent; CSP con nonce.	Prueba XSS no accede token; CSP report-only→enforce.
H03 · P2	CDN/imágenes no reproducibles (E09)	Fijar versión/digest, SRI o self-host; generar SBOM.	Build idéntico por hash y verificación automática.
H04 · P2	Enumeración en reenvío email (E08)	Respuesta uniforme, auditoría interna y control adaptativo.	Mismo status/body/latencia para estados de cuenta.
H05 · P2	Funciones largas/CC alta (E01)	Extraer casos de uso, renderers, stores y políticas.	Ninguna función >100 líneas; CC~≤15 en hotspots.
H06 · P2	Feature gate roto por BD (E04)	Postgres efímero y variables CI; migración automatizada.	NotificationsTest 10/10 verde en pipeline limpio.
H07 · P2	Sin CI/SAST/SCA versionado (E09)	Pipeline: lint, Pint, tests, audits, secret scan, SBOM.	Merge bloqueado por umbrales y evidencia retenida.
H08 · P3	Pint 195 + strict_types 2.66% (E03/E01)	Lotes pequeños; standard de strict types para nuevo PHP.	Pint verde y tendencia strict_types creciente.

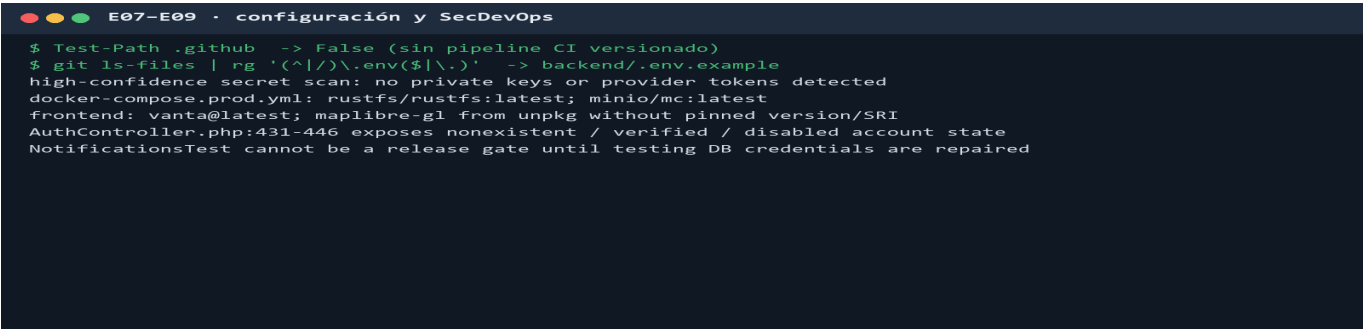


Figura 5. Evidencia E07–E09. El escaneo heurístico de secretos no halló credenciales de alta confianza; sí existe una brecha de automatización y reproducibilidad.

Horizonte	Objetivo	Entregables
0–48 h	Contención	Actualizar dependencias P1; respuesta uniforme email; fijar tags/CDN; textContent en alertas.
1 sprint	Gate seguro	CI con audits, Pint/ESLint, Postgres efímero, NotificationsTest y CSP report-only.
2–3 sprints	Reducción de deuda	Refactor auth/layout/repositorios; FormRequest/policias; cookie HttpOnly; threat model.

Confrontación ISO/IEC 25010:2023

La edición 2023 define nueve características del modelo de calidad de producto

Característica	Evaluación	Fundamento / condición para E7
Adecuación funcional	Favorable	Pruebas unitarias verdes y funcionalidad existente; ampliar regresión por roles.
Eficiencia de desempeño	No evaluada	Corresponde a E7; antes se requiere entorno reproducible y observabilidad.
Compatibilidad	Parcial	Integración Redis/Postgres/Reverb/RustFS; dependencias y tags deben fijarse.
Capacidad de interacción	Favorable con deuda	UI operativa; globals implícitos y páginas extensas elevan costo de cambio.
Fiabilidad	Condicionada	Correo reintenta y Reverb tiene fallback; feature tests están bloqueados por BD.
Seguridad	No apta aún	P1 en supply chain y cadena XSS→token; RBAC/realtime son controles fuertes.
Mantenibilidad	Condicionada	DDD limpio y duplicación baja; 42 funciones largas, 59 CC~>10 y Pint en 195 archivos.
Flexibilidad	Parcial	Capas favorecen cambio; frontend estático y acoplamiento a window/localStorage lo dificultan.
Protección ante riesgos	Parcial	Rate limit, 2FA y auditoría; faltan CSP/HSTS, CI, SBOM y alertamiento verificable.

Dictamen técnico para Rendimiento de Carga (E7)

Apto de forma condicionada para una corrida exploratoria; no apto como evaluación formal/gate. Antes de medir capacidad deben quedar verdes las pruebas funcionales, fijarse las dependencias desplegables y habilitarse métricas de app/cola/Reverb/DB. De lo contrario, E7 mediría un entorno no reproducible y ocultaría fallos de seguridad o infraestructura.

Índice de evidencia

ID	Artefacto	Hallazgos respaldados
E01–E02	E01_E02_calidad.png + métricas JSON + jscpd-report.json	LOC, complejidad, strict types, arquitectura y duplicación.
E03–E04	E03_E04_lint_pruebas.png + eslint-report.json	Lint, estilo, sintaxis y estado de pruebas.
E05	E05_dependencias.png	Composer/npm, producción vs lock completo.
E06–E08	E06_E08_controles_seguridad.png	RBAC, territorio, realtime, token, headers y correo.
E07–E09	E07_E09_secdevops.png + resumen_ejecucion.txt	CDN/Docker, CI, secretos, enumeración y BD de pruebas.

Fuentes normativas y límites

OWASP Top 10:2025: https://owasp.org/Top10/2025/0x00_2025-Introduction/ · ISO/IEC 25010:2023: <https://www.iso.org/standard/78176.html>. La auditoría es estática y de configuración: no ejecutó DAST, pentest, verificación de TLS en el host ni explotación de CVE. Los conteos ESLint y de complejidad son indicadores para priorización; la confirmación requiere pruebas dinámicas y revisión de cambios.